CASE STUDY : 2 [Securing the university Examination System].

A university uses an operating system-based Examination management system to store student records, examination marks, faculty details, and question papers. The System has three main user groups. Students, faculty, and administrators. Students should be able to view only their own marks and download permitted learning materials. faculty members needs to view Students record and Enter or modify marks. Administrators. Manage user accounts, permissions, and system configuration.

The university has assigned permissions through roles, but an audit review Identifies the following events:

- At 10:00, the account student07 has three failed login attempts.
- At 10:03, student07 successfully logs in.
- At 10:04, student07 attempts to open Exam Mark.xlsx, which contains marks for an Entire class.
- At 10:05, the system records an attempted modification of Exam marks.xlsx by student07.
- At 10:15, faculty02 modifies marks in Exam marks xlsx and saves the file Sucessfu

- At 10:30, an administrator discovers that a former faculty member's account is still active.
- The audit log is stored on the same server, and users with broad permissions may be able to modify or delete it.

The university wants to protect confidentiality, integrity, and availability, prevent unauthorized access, maintain accountability and investigate suspicious activity. You are asked to recommend appropriate operating system access-control, security administration, and auditing measures.

QUESTIONS:

1. Identify the main security problems in the case study [list atleast four risks or weakness indicated by the scenario].
2. Explain the difference between authentication and authorization using student07 as an example [distinguish identity verification from permission checking].
3. Recommend an access-control policy for students, faculty, and administration. Justify your choice].

Prepare a suitable Access control list (ACL) for Exammark.xlsx. [Specify appropriate.

[read, write, and delete permissions for each user group]

5. Explain how the principle of least privilege should be applied in this system. [State what each group needs to do and which unnecessary permissions should be removed]

6. Interpret the audit events from 10:00 to 10:05. what should the security team do next? [Explain why the sequence is suspicious without assuming that it proves an attack]

7. Identify at least five events that should be recorded in the audit logs. [Include login, file, account, ~~pren~~ permission, and/or administrative events]

8. Explain why the audit logs must be protected and recommend two ways to protect them. [Consider unauthorized modification, deletion, and investigation]

9. What action should be taken regarding the former faculty member's active account? Explain. [relate your answer to account management and access ~~control~~ removal.

10. Suggest a practical incident-response and corrective-action plan for the university. [Include investigate, access review, policy changes, and follow-up monitoring.

ANSWERS:

1→ Problems: Student07 tried to open and modify the class marks file. There was no lockout after the failed logins. A former faculty account is still active. The audit log is on the same server, so it can be edited or deleted.

2→ Authentication vs Authorization:

- Authentication is verifying identity. Student07 logging in with the correct password is authentication.
- Authorization is checking what that user is allowed to do. A student shouldn't be able to open the class marks file.

3→ policy: use RBAC. Students view only their own marks. faculty enter or modify marks for their own courses. Admin manage accounts and settings. It's simple, and access is easy to remove when a role changs.

4→ ACL (Exam marks.xlsx)
- Students : Read No, write No, delete No.
- Faculty : Read yes (own course), write yes (own course), delete No.
- Admin : Read yes, write No (with approval), delete restricted.

5→ Least privilege : Give each group only what its job need needs. Remove student access to the marks file, faculty delete rights and access to other courses, and admin rights to edit logs.

6→ 10:00 to 10:05 :- Three failed logins, a successful login, opening the marks file, then a modification attempt. This is suspicious but doesn't prove an attack, since it could be an honest mistake. The security team should preserve the logs, check the IP and device, temporarily lock the account, contact the student, and compare the file with a backup.

7→ Events to log : login success and failure, file open, edit and delete, permission changes, account creation and deletion, and admin actions.

8→ Log protection : logs are evidence, and if someone can edit or delete them, they can cover their tracks. Two ways to

protect them : store them on a separate secure server. and make them read only with backups and integrity checks.

9→ former faculty account :- disable it immediately review its activity, then delete it. This is part of offboarding in account management because access should be removed when someone leaves.

10→ Incident plan :- Contain by locking student 07's account. Investigate by checking the logs and faculty 02's change. Fix permission disable the old account and move the logs. follow up with regular access reviews, alerts and monitoring.